

Security Incident Report

Task 5 — Phishing-Related Credential Compromise

Prepared by	Prajwal
Internship	Indravex Technologies — Cyber Security Internship
Incident type	Phishing → credential compromise (Microsoft 365)
Date of report	6 September 2026

Incident Summary

In this case, an employee got an email which looked like it came from Microsoft 365, saying that he needs to reset his password urgently. The email had a link, and the employee clicked on it without checking properly. He entered his real username and password on that page, thinking it is the actual Microsoft login page. But it was fake. So basically his login details went straight to the attacker. There was no virus or malware involved here, it was just a simple phishing trick where the attacker is depending on the employee not noticing anything wrong.

Initial Findings

- The email was written like a normal password reset message, so it did not look suspicious at first glance
- Link in the email was going to a fake login page, not the actual Microsoft domain (this is the biggest giveaway if you check the URL carefully)
- Employee entered his correct credentials on this fake page before he realised something is wrong
- As of now there is no sign of any malware or file being downloaded, so it looks like only the password got stolen, nothing else (for now)

Possible Risks

- Attacker can now log in to the employee's actual Microsoft 365 account and see his mails, files, calendar, Teams chats, basically everything
- If employee is using same password somewhere else also (which most people do, honestly), those accounts are also at risk now
- Attacker might use this hacked account to send phishing mails to other employees too, and since it's coming from a known colleague's id, people will trust it more easily
- Company data sitting in that mailbox can be leaked or copied without anyone knowing immediately
- If this account had some admin access or was connected to shared mailboxes, then the damage can go much bigger than just one person's account

Immediate Actions Taken

- First thing, reset the employee's password immediately, but from a safe/trusted device, not by clicking anything from that same phishing mail
- Logged out all active sessions of that account so attacker gets kicked out even if he was already inside
- Turned on MFA (multi factor authentication) on the account, in case it was not already enabled — this is honestly something that should be default for everyone
- Informed the IT/security team right away so they can track this properly and keep a record
- Told the employee to not delete that phishing email, we need it to check the sender address and the fake link later

Containment

- Checked the sign-in history and logs of that account for anything unusual, like login from a different city/country, or new forwarding rules added
- Specifically checked for auto-forwarding rules in the mailbox, because attackers often set these up quietly so they can keep reading mails even after password is changed
- Reported the phishing link/sender so it can be blocked at the email gateway level, so it doesn't reach other people also
- Also checked if the same phishing mail was sent to other employees in the company, and warned them beforehand so nobody else falls for it

Recovery Plan

- Double-check that account is fully clean now — new password set, MFA active, and no weird forwarding rules or unknown app permissions left behind
- Go through whatever actions were done from that account during the time it was compromised (mails sent, files shared etc.) and undo/flag anything suspicious
- If employee was using this same password on other personal or work accounts, ask him to change those too, better safe than sorry
- Only give back normal access once everything above is confirmed clean, and keep an eye on the account for some more days just to be sure

Future Prevention Recommendations

- Company should conduct phishing awareness training for all employees — simple things like checking sender's actual email id and hovering over links before clicking can prevent most of these cases
- MFA should be made compulsory for every account, not optional, so that even if password gets leaked, attacker still can't get in easily
- Do fake/simulated phishing tests once in a while to actually see how employees react, rather than just giving them a training video and hoping they remember it
- Set up email filters that can catch look-alike domains and flag emails that are pretending to be from internal company addresses
- Encourage employees to use different passwords for different accounts (a password manager helps a lot here), so one leaked password doesn't put everything else at risk too